

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Thu 18 Jun 2026, at 21:13:53

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=Medium \(2\)](#)
 - [Risk=Informational, Confidence=Medium \(1\)](#)

- [Appendix](#)
- [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://localhost:3000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (16.7%)	2 (33.3%)	0 (0.0%)	3 (50.0%)
	Low	0 (0.0%)	0 (0.0%)	2 (33.3%)	0 (0.0%)	2 (33.3%)
	Informational	0 (0.0%)	0 (0.0%)	1 (16.7%)	0 (0.0%)	1 (16.7%)
	1					
Total	0 (0.0%)	1 (16.7%)	5 (83.3%)	0 (0.0%)	6 (100%)	

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		Informational			
		High	Medium	Low	(>= Informational)
		(= High)	(>= Medium)	(>= Low)	
Site	http://localhost:3000	0	3	2	1
	0	(0)	(3)	(5)	(6)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	3 (50.0%)
Cross-Domain Misconfiguration	Medium	2 (33.3%)
Missing Anti-clickjacking Header	Medium	3 (50.0%)
Total		6

Alert type	Risk	Count
<u>Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)</u>	Low	3 (50.0%)
<u>X-Content-Type-Options Header Missing</u>	Low	3 (50.0%)
<u>Modern Web Application</u>	Informational	3 (50.0%)
Total		6

Alerts

Risk=Medium, Confidence=High (1)

http://localhost:3000 (1)

Content Security Policy (CSP) Header Not Set (1)

► GET http://localhost:3000/robots.txt

Risk=Medium, Confidence=Medium (2)

http://localhost:3000 (2)

Cross-Domain Misconfiguration (1)

► GET http://localhost:3000/robots.txt

Missing Anti-clickjacking Header (1)

► GET http://localhost:3000

Risk=Low, Confidence=Medium (2)

[http://localhost:3000 \(2\)](#)

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

► GET http://localhost:3000

X-Content-Type-Options Header Missing (1)

► GET http://localhost:3000

Risk=Informational, Confidence=Medium (1)

[http://localhost:3000 \(1\)](#)

Modern Web Application (1)

► GET http://localhost:3000

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
--------	---

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP 2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html 3. https://www.w3.org/TR/CSP/ 4. https://w3c.github.io/webappsec-csp/ 5. https://web.dev/articles/csp 6. https://caniuse.com/#feat=contentsecuritypolicy 7. https://content-security-policy.com/

2. Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)
CWE ID	264
WASC ID	14
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Pol

3. Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15

4. Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	1. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework 2. https://www.troyhunt.com/shhh-dont-let-your-response-headers/

5. X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	1. https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) 2. https://owasp.org/www-community/Security-Headers

6. Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)
---------------	--